

Leakage of Langfuse API keys in team exception handling in berriai/litellm

✓ Valid

Reported on Nov 9th 2024

Description

When proxy_server.py encounters an error while parsing the team settings, it leaks out the actual secret keys.

Proof of Concept

Use these settings:

```
litellm_settings:
  telemetry: False
  drop_params: True
  return_response_headers: True
  redact_messages_in_exceptions: True
  cache: True
  cache_params:
    type: s3
    s3_bucket_name: os.environ/CACHING_S3_BUCKET_NAME
    s3_region_name: os.environ/CACHING_AWS_DEFAULT_REGION
    s3_aws_access_key_id: os.environ/CACHING_AWS_ACCESS_KEY_ID
    s3_aws_secret_access_key: os.environ/CACHING_AWS_SECRET_ACCESS_KEY
    s3_endpoint_url: os.environ/CACHING_AWS_ENDPOINT_URL_S3
  failure_callback: ["sentry", "langfuse"]
  request_timeout: 3600
  success_callback: ["langfuse", "s3"]
  s3_callback_params:
    s3_bucket_name: os.environ/LOGGING_S3_BUCKET_NAME
    s3_region_name: os.environ/LOGGING_AWS_DEFAULT_REGION
    s3_aws_access_key_id: os.environ/LOGGING_AWS_ACCESS_KEY_ID
    s3_aws_secret_access_key: os.environ/LOGGING_AWS_SECRET_ACCESS_KEY
    s3_endpoint_url: os.environ/LOGGING_AWS_ENDPOINT_URL_S3
  default_team_settings:
    - team_id: test_dev
      success_callback: ["langfuse", "s3"]
      langfuse_secret: os.environ/LANGFUSE_PRIVATE_KEY_TEST
      langfuse_public_key: os.environ/LANGFUSE_PUBLIC_KEY_TEST
    - team_id: my_workflows
      success_callback: ["langfuse", "s3"]
```

```
langfuse_secret: os.environ/LANGFUSE_PRIVATE_KEY_WORKFLOWS
langfuse_public_key: os.environ/LANGFUSE_PUBLIC_KEY_WORKFLOWS
```

Then send a completion request with an API key from the `my_workflows` team. You end up getting this error returned to the client:

```
{"error":{"message":"team_id missing from team: {'success_callback': ['langfuse']},
```

This is really bad, since `langfuse_secret` and `langfuse_public_key` give full access to the Langfuse project that is storing all your requests.

I am not sure when this showed up. Somewhere between v1.52.1 and v1.51.3.

Impact

Disclosing Langfuse secrets (confirmed), and possibility other team based secrets.

Occurrences

 `proxy_server.py` L1469-L1493

⚙️ We are processing your report and will contact the **berriai/litellm** team within 24 hours. a year ago



✎ **huntr-helper** modified the Severity from High (8.7) to High (7.5) a year ago



David Manouchehri commented a year ago

Researcher

`team_id` is randomly omitted sometimes from random teams. This is a really hard issue to figure out the cause.

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. a year ago



David Manouchehri commented a year ago

Researcher

This was made public by someone else after I reported it. They don't seem to have noticed the leakage.

<https://github.com/BerriAI/litellm/issues/6787>



David Manouchehri commented a year ago

Researcher

I finally managed to fix it I think.



The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Ethan Silvas validated this vulnerability a year ago



manouchehri has been awarded the disclosure bounty ✓



The fix bounty is now up for grabs



The researcher's credibility has increased: +7



CVE-2025-0330 assigned to this report. a year ago



We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago



We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours a year ago



This vulnerability has now been published a year ago



CVE-2025-0330 has now been published 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2025-0330

Published

Vulnerability Type

CWE-1230: Exposure of Sensitive Information Through Metadata

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version
v1.52.1

Visibility
Public

Status
Awaiting fix

Disclosure Bounty
\$750

Fix Bounty
\$187.5

Found by



David Manouchehri
@manouchehri
UNPROVEN


Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

